

VIDA COTIDIANA

V1 — Software Architecture and Product Specification

Version 1.0 — Draft Baseline

Generated: 2026-08-09

GENERATED ARTIFACT — derived from Documentacion/ (Markdown/YAML), which remains the source of truth.

2. Document Control

Field	Value
Document title	V1 — Software Architecture and Product Specification
Product	Vida Cotidiana
Version	1.0 (Draft Baseline)
Status	Documentation baseline — approved product/architecture decisions; V1 development gate audit passed; several non-blocking TBDs remain
Date generated	2026-08-09 (last updated: V1 development gate audit)
Prepared by	AI documentation agent (Claude), on behalf of the Product Owner
Approval	Pending explicit Product Owner / stakeholder sign-off on this generated baseline
Source of truth	Documentacion/ (Markdown) and Documentacion/openapi/openapi.yaml — this document is a generated, human-readable derivative

Change history

Date	Change
2026-08-09	Initial baseline generated after the 15 blocking V1 decisions were approved (28-v1-decision-pack.md) and the final readiness review (29-v1-final-readiness.md).
2026-08-09 (audit cycle)	Regenerated after the "V1 development gate" audit: corrected stale references, closed OpenAPI/data-model gaps, added UC-14/AC-017, rebuilt the traceability matrix (see 32-v1-development-gate-audit.md).

Related source documents

- AI-CONTEXT.md — project constitution for AI agents
- 22-decision-log.md — Architecture Decision Records (ADR-001 to ADR-012)
- 28-v1-decision-pack.md — the 15 approved V1 decisions (DEC-001 to DEC-015)
- 29-v1-final-readiness.md — V1 readiness audit (status: READY)
- 30-documentation-consistency-review.md — consistency review prior to this generated pack
- 32-v1-development-gate-audit.md — V1 development gate audit (external findings validated, source docs corrected)
- 01-scope.md, 03-prd.md, 04-use-cases.md, 05-user-flows.md — product documentation
- 06-c4.md, 07 to 08c architecture documents — architecture documentation
- 09-data-model.md, openapi/openapi.yaml, 10-api-openapi.md — data and API contract
- 11-auth-security.md, 21-security.md — security documentation
- 12-traceability.md, 13-acceptance.md, 26-v1-backlog.md — traceability and acceptance

Table of Contents

- 1. Cover
- 2. Document Control
- 3. Executive Summary
- 4. Product Scope
- 5. V1 Objectives
- 6. Functional Requirements
- 7. Non-Functional Requirements
- 8. User Roles and Permissions
- 9. Use Cases
- 10. User Flows
- 11. Sharing Model
- 12. Invitation Lifecycle
- 13. Reminder Lifecycle
- 14. Notification Architecture
- 15. Identity and Authentication
- 16. Keycloak Architecture
- 17. C4 Architecture
- 18. Backend Architecture
- 19. Android Architecture
- 20. iOS Architecture
- 21. Web Architecture
- 22. Data Model
- 23. API Architecture
- 24. Security Model
- 25. Threat Model
- 26. Data Retention
- 27. CI/CD and Environments
- 28. Traceability Matrix
- 29. Acceptance Criteria
- 30. Decision Log
- 31. Open Questions
- 32. V1 Readiness

3. Executive Summary

Vida Cotidiana is a platform to help a person organize everyday-life information and activities. V1 is deliberately scoped as a minimal, secure, multi-platform MVP: account management, personal and simple shared reminders, and notifications — nothing more.

V1 targets three platforms from day one — Android, iOS and Web (ADR-005) — sharing the same backend, API contract and data model, without assuming shared client code across platforms.

On 2026-08-09 the Product Owner closed the 15 decisions that were blocking the start of V1 development (28-v1-decision-pack.md): the completion semantics of shared reminders, the deletion behaviour of shared reminders, the invitation lifecycle, the identity provider (Keycloak), the push-token storage model, the iOS and Web technology stacks, the cloud provider (AWS), the transactional email provider (Amazon SES), the push notification provider (Firebase Cloud Messaging), minimum supported OS/browser versions, email verification, and the account retention/deletion policy.

A consistency review performed immediately before generating this document (30-documentation-consistency-review.md) found only minor, non-blocking editorial drift — no approved decision was found contradicted, reopened, or silently reinterpreted. The overall V1 readiness status is READY for core development (29-v1-final-readiness.md), with a short list of remaining TBDs that are explicitly non-blocking (product naming, market, minor UX edge cases, and a handful of implementation-level technical details).

This document consolidates the current state of the V1 product, architecture, data, API, security and traceability documentation into a single, cross-referenced reference for architecture review, product review, technical audit, stakeholder presentation, and development handoff. It supersedes no source document — Documentacion/ remains authoritative.

4. Product Scope

Vida Cotidiana aims to help a person organize everyday-life information and activities. V1 intentionally excludes AI and Finance, both of which are explicitly reserved for a phase after V4 (ADR-003, ADR-004), for reasons of security, privacy, cost and trust.

V1 — confirmed scope

- Create an account (Android, iOS, Web) via Keycloak.
- Sign in / sign out.
- Session / device management.
- View Home (summary of pending reminders).
- Create, view, update and complete reminders/tasks.
- Share a reminder with one or more people via invitation (owner + collaborators model, ADR-006).
- Receive local notifications and backend push notifications (FCM) for own and shared reminders.
- Baseline privacy, security, technical audit trail and observability.
- Basic account settings, including requesting account deletion (soft delete, FR-013).

Roadmap by version

Version	Objective	Result
V1	MVP	Functional application: account + Home + tasks/reminders, three platforms
V2	Stability	Reliable, secure and measurable product
V3	Evolution	New features + performance + scalability
V4	Final	Full approved scope
Post-V4	AI / Finance	Separate phases, subject to validation

Out of scope (V1, and beyond unless noted)

- Banking integration, account statements, Open Banking.
- AI (post-V4, ADR-003) and Finance (post-V4, ADR-004).
- Marketplace, affiliates, advertising.
- Microservices / complex distributed architecture (ADR-001).
- File/attachment uploads on reminders.
- Groups, households, teams, or granular roles beyond the simple owner/collaborator model.
- Social search or contact book for sharing.

A documentation conflict identified during the initial audit — the early draft excluded iOS and Web from V1, while the project constitution requires all three platforms — was resolved in favour of building all three platforms from V1 (ADR-005).

5. V1 Objectives

Definition of success for V1 (02-roadmap.md):

- A user can register and sign in on Android, iOS and Web.
- A user can create and complete a reminder.
- A user can share a reminder with one or more people via invitation; recipients can accept/reject/view/complete according to their permission (ADR-006).
- A user receives local and push notifications for own and shared reminders (ADR-007).
- Data is isolated per user and per explicit sharing relationship (owner vs. collaborator).
- The application handles network errors gracefully.
- The backend has automated tests.
- CI blocks changes that fail build or tests.
- No secrets exist in the repository.
- The OpenAPI contract is versioned.

Evolution rule: a version must not require rebuilding the previous domain. Modules are added behind stable contracts.

6. Functional Requirements

Presented here in ascending numeric order for readability; see 30-documentation-consistency-review.md for a note on the physical ordering of 03-prd.md.

ID	Title	Summary
FR-001	Registro	Crear cuenta vía Keycloak (OIDC/OAuth 2.1 self-hosted, DEC-004). No se implementa almacenamiento de contraseñas propio. Verificación de email delegada a Keycloak (DEC-014). Email obligatorio en el registro: TBD.
FR-002	Autenticación	El usuario inicia y cierra sesión mediante Keycloak (Authorization Code + PKCE); el backend es resource server, no emite sesión propia.
FR-003	Home	El usuario autenticado ve un resumen mínimo de sus pendientes.
FR-004	Recordatorios	CRUD: crear, consultar, editar, completar, eliminar. Campos V1: id, título, descripción opcional, fecha/hora opcional, estado, timestamps.
FR-005	Notificaciones locales	Notificación local en el dispositivo cuando existe fecha/hora configurada.
FR-006	Cuenta	El usuario puede cerrar sesión y consultar información básica de su cuenta.
FR-007	Compartir recordatorio	El propietario invita a una o varias personas por email o username (1:N). La invitación queda PENDING hasta aceptación explícita, expira a los 7 días (ASSUMPTION) y puede cancelarse. No se revela si un email pertenece a una cuenta existente (SEC-001).
FR-008	Aceptar invitación	El destinatario acepta una invitación pendiente; se crea una colaboración activa con los permisos de FR-009.
FR-009	Permisos de colaborador	Estado de completado único global por recordatorio (DEC-001). El colaborador ve y completa/revierte el estado; no edita, elimina, cambia el propietario ni vuelve a compartir.
FR-010	Revocar / rechazar / cancelar / expirar	Rechazo (INVITATION.REJECTED), cancelación de invitación pendiente (INVITATION.CANCELLED, por el propietario) y revocación de acceso ya aceptado (REMINDER_SHARE.REVOKED) son conceptos distintos (DEC-003). Al eliminar un recordatorio se elimina en cascada y se notifica a los colaboradores activos (DEC-002).
FR-011	Notificaciones push	Backend emite push vía Firebase Cloud Messaging (FCM, DEC-010), detrás del puerto PushNotificationSender (ADR-007), para: recordatorio programado, invitación recibida/aceptada/rechazada/cancelada, cambios en recordatorio compartido, revocación, eliminación de recordatorio compartido.

ID	Title	Summary
FR-012	Registro de dispositivo para push	El cliente registra su token de push contra el backend (DEVICE_PUSH_TOKEN, DEC-005), soportando múltiples dispositivos por usuario.
FR-013	Eliminar cuenta	El usuario solicita la eliminación de su cuenta; soft delete con 30 días de gracia antes de la purga definitiva (DEC-015). Consecuencia directa de la política de retención aprobada.

7. Non-Functional Requirements

ID	Title	Summary
NFR-001	Seguridad	HTTPS en toda la API; autorización validada por recurso.
NFR-002	Privacidad	Solo se almacenan los datos necesarios para V1 (minimización).
NFR-003	Disponibilidad	Objetivo inicial: TBD.
NFR-004	Rendimiento	Objetivo de API p95: TBD.
NFR-005	Mantenibilidad	Código modular, testeable, con separación de responsabilidades.
NFR-006	Observabilidad	Errores, métricas y logs técnicos sin secretos ni contenido sensible.
NFR-007	Accesibilidad	Soporte inicial de tamaños de fuente del sistema y componentes accesibles.
NFR-008	Compatibilidad	Android API 30 (DEC-011); iOS 17 (DEC-012); navegadores: últimas 2 versiones mayores de Chrome/Edge/Firefox, Safari desktop/iOS (actual y anterior), Chrome Android (actual) (DEC-013). Dispositivos soportados: TBD.
NFR-009	Consistencia multiplataforma	Android, iOS y Web ofrecen el mismo modelo funcional y de datos, sin código compartido entre plataformas.
NFR-010	Retención y eliminación de datos	Soft delete de cuenta con 30 días de gracia (DEC-015). Emails de invitados sin cuenta se purgan tras expiración/rechazo/cancelación de la invitación (ASSUMPTION: 90 días).

8. User Roles and Permissions

Authorization is resource-based, not a global role system. Two roles exist on a reminder: OWNER and COLLABORATOR.

Role	Can	Cannot
OWNER	View, edit, complete/revert, delete, invite collaborators, cancel pending invitations, list collaborators/invitations, revoke a collaborator's access	—
COLLABORATOR (REMINDER_SHARE.status = ACTIVE)	View the reminder, mark completed / revert to pending (shared global state, DEC-001)	Edit title/description/date, delete, change owner, re-share, manage other collaborators' permissions

- Authentication ≠ authorization; every resource operation verifies ownership.
- Deny-by-default; least privilege; never trust a client-supplied userId.
- A REVOKED REMINDER_SHARE loses authorization immediately — no grace window, no stale authorization cache.
- The authorization model is designed to allow future (V2/V3) roles, households and granular permissions, without implementing that complexity in V1.

9. Use Cases

ID	Title	Actor	Summary
UC-01	Registrarse	Visitante	Registro delegado a Keycloak (Authorization Code + PKCE); verificación de email gestionada por Keycloak (DEC-014).
UC-02	Iniciar sesión	Usuario	Autenticación contra Keycloak; el backend valida el token como resource server en cada request.
UC-03	Crear recordatorio	Usuario	Alta de un recordatorio con título y, opcionalmente, fecha/hora.
UC-04	Completar recordatorio	Usuario	Marca el recordatorio como completado; estado único global (DEC-001).
UC-05	Eliminar recordatorio	Propietario	Si hay colaboradores activos, se les notifica por push y se elimina en cascada (DEC-002).
UC-06	Cerrar sesión	Usuario	Elimina credenciales/tokens locales; invalida sesión cuando aplique.
UC-07	Compartir recordatorio	Propietario	Crea una invitación PENDING por email o username, sin revelar si el email tiene cuenta.
UC-08	Aceptar invitación	Destinatario	Acepta una invitación pendiente; se activa la colaboración con permisos de FR-009.
UC-09	Rechazar invitación	Destinatario	Rechaza una invitación pendiente; no se otorga acceso.
UC-10	Revocar acceso compartido	Propietario	Actúa exclusivamente sobre REMINDER_SHARE (colaboración ya aceptada); efecto inmediato (DEC-003).
UC-11	Recibir notificación push	Usuario	Recibe push vía FCM para eventos de recordatorios propios y compartidos (incluye eliminación, DEC-002).
UC-12	Registrar dispositivo para push	Usuario autenticado	Registra/actualiza el token de push del dispositivo actual (DEVICE_PUSH_TOKEN).
UC-13	Eliminar cuenta	Usuario autenticado	Solicita la eliminación de su cuenta; entra en PENDING_DELETION con purga a los 30 días.
UC-14	Cancelar invitación pendiente	Propietario	Actúa exclusivamente sobre INVITATION en estado PENDING (transición atómica → CANCELLED); distinto de revocar (UC-10, sobre REMINDER_SHARE).

10. User Flows

Full Mermaid diagrams are maintained in 05-user-flows.md. The main flows are summarized below as ordered steps.

Main flow

- 1. App checks session validity
- 2. If invalid → Login → Authentication → Home
- 3. If valid → Home directly
- 4. Home → view pending items → create reminder → validate → save → back to Home
- 5. Home → complete a reminder → back to Home

Network error flow

- 1. Action → API call
- 2. Success → update UI
- 3. Temporary error → show recoverable state
- 4. 401 → re-authenticate
- 5. 403 → show no-permission state
- 6. Other 4xx → show validation error
- 7. 5xx → generic error + retry

Sharing / invitation flow (ADR-006)

- 1. Owner opens a reminder and selects Share
- 2. Enters recipient email or username
- 3. Backend validates ownership and creates an invitation (PENDING, 7-day expiry)
- 4. If the recipient has an account → push notification sent
- 5. If not → invitation stays associated with the email
- 6. Recipient accepts → active collaboration (view + complete)
- 7. Recipient rejects → REJECTED, no access
- 8. No response in 7 days → EXPIRED, no access
- 9. Owner can revoke an active collaborator's access at any time → immediate effect

Push notification flow (ADR-007, DEC-010)

- 1. A domain event occurs (scheduled reminder, invitation received/accepted/rejected/cancelled, change on a shared reminder, revocation, deletion of a shared reminder)
- 2. Scheduled-reminder events are resolved locally on the client
- 3. All other events are sent through Firebase Cloud Messaging (FCM), behind the PushNotificationSender port
- 4. The user's registered device(s) receive the push notification

11. Sharing Model

A reminder has exactly one owner (OWNER, full control) and zero or more collaborators (COLLABORATOR, 1:N) added through an explicit, opt-in invitation flow — never implicit access (ADR-006).

- Recipient identification: by email (works even if the invitee has no account yet) or by username (existing users only) — owner's choice (FR-007).
- Cardinality: one owner, many collaborators per reminder (1:N).
- No enumeration: the system never reveals whether an email belongs to an existing account (SEC-001).
- Collaborator permissions are intentionally minimal: view, and toggle the single shared completion state (DEC-001). No edit, delete, re-share, or permission management.
- The authorization model is deliberately kept simple for V1 (owner/collaborator only) while being designed so that households, groups and granular roles can be added later (V2/V3) without a redesign.

12. Invitation Lifecycle

DEC-003 fixed a design defect found during the readiness review: the INVITATION state machine did not have a CANCELLED state (needed for the existing "cancel a pending invitation" action) and incorrectly included REVOKED, which conceptually belongs to an already-accepted collaboration, not to the invitation itself.

State	Meaning	Reachable from
PENDING	Invitation created, awaiting the recipient's decision	Initial state
ACCEPTED	Recipient accepted; a REMINDER_SHARE (ACTIVE) is created	PENDING
REJECTED	Recipient explicitly declined; no access granted	PENDING
EXPIRED	No response within 7 days (ASSUMPTION); no access granted	PENDING
CANCELLED	Owner cancelled the pending invitation before a response	PENDING

Access revocation after acceptance is a distinct concept and lives exclusively on REMINDER_SHARE.status (ACTIVE → REVOKED), never on INVITATION (DEC-003).

13. Reminder Lifecycle

Stage	Description
Create	Owner creates a reminder with a title and, optionally, description and due date/time (FR-004).
Edit	Only the owner can edit title, description, date; collaborators cannot (FR-009).
Complete / revert	Single global completion state (DEC-001), togglable by the owner or any active collaborator; idempotent (AC-005).
Share	Owner invites collaborators (FR-007); see Sharing Model.
Delete	Owner-only. Cascades to INVITATION and REMINDER_SHARE; active collaborators are notified via push before/at deletion (DEC-002, AC-013).

14. Notification Architecture

Two complementary channels exist:

- Local notifications: resolved entirely on the client, for a reminder's own due date/time (FR-005). No backend involvement.
- Push notifications: emitted by the backend for events requiring cross-device or cross-user synchronization — invitation received/accepted/rejected/cancelled, changes on a shared reminder, revocation, deletion (FR-011).

The backend abstracts the push provider behind a dedicated port, `PushNotificationSender` (ADR-007), with a single concrete adapter for Firebase Cloud Messaging (FCM), used for Android natively, iOS via the FCM-APNs bridge, and Web via the Web Push protocol (DEC-010). A push provider failure must be best-effort and must never fail the primary operation (AC-012).

Device tokens are stored in `DEVICE_PUSH_TOKEN`, supporting multiple simultaneously registered devices per user (DEC-005). Clients register (POST `/me/devices`) on session start and deregister (DELETE `/me/devices/{id}`) on logout (FR-012).

15. Identity and Authentication

Identity is fully delegated to Keycloak (ADR-008, DEC-004) — an OIDC/OAuth 2.1 self-hosted provider with passkey/WebAuthn and MFA support. The application does not implement its own password storage, verification, or login endpoint.

- Clients (Android, iOS, Web) authenticate directly against Keycloak using Authorization Code + PKCE.
- The backend acts purely as an OAuth2/OIDC resource server (Spring Security OAuth2 Resource Server), validating the bearer token on every request.
- There is no POST /auth/login on the backend — this corrects a documentation conflict identified in the initial readiness review (27-v1-readiness-review.md §4.1).
- Email verification is delegated to Keycloak's built-in "Verify Email" required action; the application does not implement a parallel verification system (DEC-014).
- Session management, MFA, passkeys, brute-force protection and account recovery are all handled by Keycloak.

16. Keycloak Architecture

Keycloak was selected (DEC-004) after comparing four self-hosted, OIDC-compliant identity providers:

Provider	Notes
Keycloak (chosen)	Most mature and feature-complete; native passkey support since v25; higher operational overhead (tuning/clustering); Apache 2.0.
Zitadel	Event-sourced Go architecture, lighter to operate; passwordless/WebAuthn by design; built for multi-tenant SaaS; Apache 2.0 (some enterprise features separate).
Authentik	Strong developer experience, GA WebAuthn, also SAML/LDAP/RADIUS; more proxy/SSO-oriented than native-app-oriented; MIT.
Ory (Kratos + Hydra)	Requires assembling two services (identity + OAuth/OIDC); higher operational complexity; Apache 2.0.

All four expose a standard OIDC contract, so backend and client integration is equivalent regardless of provider; the real differentiators are maturity, operational weight and feature scope. Migrating away from Keycloak later remains feasible precisely because the integration follows the OIDC standard rather than a proprietary contract.

Integration pattern: one Keycloak realm for Vida Cotidiana, with a separate OIDC client registration per platform (Android, iOS, Web), and the Spring Boot backend configured as an OAuth2 Resource Server validating JWTs issued by Keycloak.

17. C4 Architecture

System Context

Element	Type	Description
User	Person	Uses the app on Android, iOS or Web
Vida Cotidiana	System	Everyday-life organization platform
Keycloak	External system	OIDC identity provider (self-hosted, DEC-004)
Firebase Cloud Messaging	External system	Unified push provider behind PushNotificationSender (DEC-010)
Amazon SES	External system	Transactional email for invitations (DEC-009)

Containers

Container	Technology	Responsibility
Android App	Kotlin, Jetpack Compose	UI and local storage
iOS App	Swift, SwiftUI (DEC-006)	UI and local storage
Web App	React, TypeScript, SPA (DEC-007)	Web UI
Backend API	Java 21, Spring Boot	Modular monolith, hosted on AWS (DEC-008)
PostgreSQL	SQL	Application data, invitations and sharing
Object Storage	S3-compatible	Prepared conceptually; not implemented in V1 (FUTURE)

Full Mermaid C4 diagrams (context and container) are maintained in 06-c4.md.

18. Backend Architecture

Decision: modular monolith for V1-V3 (ADR-001) — single deployment, lower operational cost, simpler transactions and debugging, explicit domain boundaries, with the option to extract modules later if concrete needs (independent scaling, independent teams, clear operational limits) appear.

Stack

- Java 21 LTS
- Spring Boot 3.x
- Spring Security
- Spring Data JPA / Hibernate
- PostgreSQL
- Flyway
- Bean Validation
- OpenAPI
- Testcontainers

Module structure

- shared
- identity
- user — owns soft-delete flow (deletion_status, purge_at) and its purge job (DEC-015)
- reminder — owns the Reminder aggregate
- sharing — INVITATION and REMINDER_SHARE; does not access reminder's internal tables directly; owns the orphaned-invitation purge job (DEC-015)
- notification — PushNotificationSender port with an FCM adapter (DEC-010); owns DEVICE_PUSH_TOKEN (DEC-005)
- audit

Layering rules

- domain does not depend on infrastructure
- API contains no business rules
- application orchestrates use cases
- repositories are domain/application interfaces
- infrastructure implements adapters
- modules never access another module's internal repositories directly

19. Android Architecture

Minimum SDK: API 30 / Android 11 (DEC-011).

Stack

- Kotlin
- Jetpack Compose
- ViewModel
- Coroutines / Flow
- Navigation Compose
- Hilt
- Retrofit / OkHttp
- Kotlin Serialization
- Room (only if V1 needs local persistence)
- Android Keystore for sensitive material

Pattern

Clean Architecture + MVVM with unidirectional data flow. MVI is not globally mandatory — used only where complex state justifies it.

Security

- No password storage on-device
- Tokens in secure storage
- No tokens in logs
- Minimum permissions; Network Security Config
- Never trust client-side data for authorization

Push (DEC-005 / DEC-010)

The Android client obtains the FCM token and registers it with the backend (POST /me/devices) on sign-in, and requests deletion (DELETE /me/devices/{id}) on sign-out.

20. iOS Architecture

Minimum version: iOS 17 (DEC-012).

Decision (DEC-006/ADR-010): Swift + SwiftUI native. No cross-platform framework (Kotlin Multiplatform, Flutter, React Native) was chosen, per the project constitution's preference for native support, maintainability, security, performance, native integration and longevity over shared-code savings.

Stack

- Swift
- SwiftUI
- Combine or native async/await (to be fixed at project bootstrap)
- URLSession (or a lightweight networking library)
- Keychain for sensitive material
- AppAuth-iOS (or equivalent) for Authorization Code + PKCE against Keycloak
- Firebase SDK (FCM) for push

Pattern

Clean Architecture + MVVM, conceptually analogous to Android, without sharing code.

Security

- No password storage (identity delegated to Keycloak)
- Tokens in Keychain, never in UserDefaults
- No tokens in logs
- App Transport Security without exceptions unless explicitly justified

21. Web Architecture

Decision (DEC-007/ADR-011): React + TypeScript as an SPA (no SSR/Next.js in V1). V1 requires an authenticated session with no confirmed public-SEO need, so a pure SPA is sufficient and simpler to operate.

Supported browsers (DEC-013): latest 2 major versions of Chrome, Edge and Firefox (desktop); Safari desktop (current and previous); Safari on iOS (current and previous); Chrome on Android (current).

Stack

- React + TypeScript
- HTTP client for the /api/v1 REST API
- OIDC library for SPAs (Authorization Code + PKCE) against Keycloak
- Firebase SDK (Web Push)
- browserslist configured per DEC-013

Open, non-blocking security consideration

Because the Web client is a public SPA, the exact OIDC token storage pattern is still a pending implementation detail (not a business decision): in-memory storage with silent renewal vs. a Backend-for-Frontend with an httpOnly cookie. Given DEC-007 explicitly fixed "SPA" (not BFF), in-memory storage with silent renewal is the option most consistent with the decision already made. This is tracked as an open technical item in 25-open-questions.md and does not block V1.

22. Data Model

Core entities (09-data-model.md):

Entity	Key fields	Notes
USER	id, email (UK), username (UK, nullable), status, deletion_status, deletion_requested_at, purge_at, created_at, updated_at	Cuenta de usuario. Soft delete vía deletion_status (DEC-015).
REMINDER	id, owner_user_id (FK), title, description, due_at, status, version, created_at, updated_at	Recordatorio. status es un único estado global (DEC-001). version: bloqueo optimista (RECOMMENDATION técnica).
INVITATION	id, reminder_id (FK, ON DELETE CASCADE), inviter_user_id (FK), invited_email, invited_user_id (FK, nullable), status, expires_at, created_at, resolved_at	Invitación a colaborar. status: PENDING/ACCEPTED/REJECTED/EXPIRED/CANCELLED (DEC-003, sin REVOKED). Transiciones desde PENDING son atómicas (evita condiciones de carrera).
REMINDER_SHARE	id, reminder_id (FK, ON DELETE CASCADE), collaborator_user_id (FK), invitation_id (FK), status, created_at, revoked_at	Colaboración activa. status: ACTIVE/REVOKED (la revocación vive aquí, DEC-003).
DEVICE_PUSH_TOKEN	id, user_id (FK), platform, token (UK), created_at, last_seen_at	Token de push por dispositivo; múltiples filas por usuario (DEC-005); token único (upsert en POST /me/devices).

Relationships

- USER 1—N REMINDER (owns)
- USER 1—N REMINDER_SHARE (is a collaborator on)
- USER 1—N INVITATION (receives, if it has an account)
- USER 1—N DEVICE_PUSH_TOKEN (registers)
- REMINDER 1—N REMINDER_SHARE (shared with)
- REMINDER 1—N INVITATION (originates)

Key constraints

- UUID identifiers, non-guessable
- USER.email unique; USER.username unique when not null
- REMINDER_SHARE(reminder_id, collaborator_user_id) unique — prevents duplicate collaborations
- Partial unique index INVITATION(reminder_id, invited_email) WHERE status = 'PENDING' — backs the 409 on duplicate invitations (AC-007)
- INVITATION.reminder_id and REMINDER_SHARE.reminder_id use ON DELETE CASCADE (DEC-002)
- Indexes on user_id/owner_user_id, INVITATION(invited_email), INVITATION(status, expires_at), REMINDER_SHARE(collaborator_user_id), DEVICE_PUSH_TOKEN(user_id)
- Timestamps in UTC; migrations versioned with Flyway

23. API Architecture

Canonical contract: Documentacion/openapi/openapi.yaml (OpenAPI 3.0.3). Base path /api/v1, JSON content type, UUID identifiers, ISO-8601 UTC timestamps. Security is declared via an OAuth2/OIDC scheme (keycloakBearer) validating tokens issued by Keycloak; the contract defines no /auth/* endpoint of its own. List endpoints (GET /reminders, GET /reminders/{id}/shares, GET /me/invitations) are paginated (page/size, PageMeta). REMINDER carries a version field for optimistic locking, validated on PATCH and optionally on complete.

Endpoints (V1)

Method	Path	Description
GET	/api/v1/me	Consultar el usuario autenticado.
DELETE	/api/v1/me	Solicitar eliminación de cuenta (202, soft delete).
GET	/api/v1/me/devices	Listar dispositivos registrados para push.
POST	/api/v1/me/devices	Registrar/actualizar (upsert por token) el token de push del dispositivo actual.
DELETE	/api/v1/me/devices/{deviceId}	Eliminar el registro de un dispositivo.
GET	/api/v1/reminders	Listar recordatorios propios y compartidos (paginado: page/size).
POST	/api/v1/reminders	Crear un recordatorio (body: title, description, dueAt).
GET	/api/v1/reminders/{id}	Consultar un recordatorio.
PATCH	/api/v1/reminders/{id}	Editar un recordatorio (solo propietario; requiere version, bloqueo optimista).
DELETE	/api/v1/reminders/{id}	Eliminar un recordatorio (solo propietario; cascada + notificación).
POST	/api/v1/reminders/{id}/complete	Completar / revertir (propietario o colaborador activo; version opcional).
GET	/api/v1/reminders/{id}/shares	Listar colaboradores e invitaciones (solo propietario, paginado).
POST	/api/v1/reminders/{id}/shares	Crear invitación por email o username (solo propietario).
DELETE	/api/v1/reminders/{id}/shares/{shareId}	Revocar el acceso de un colaborador (solo propietario).
GET	/api/v1/me/invitations	Listar invitaciones pendientes recibidas (paginado).
POST	/api/v1/invitations/{invitationId}/accept	Aceptar una invitación (solo destinatario; transición atómica).
POST	/api/v1/invitations/{invitationId}/reject	Rechazar una invitación (solo destinatario; transición atómica).

Method	Path	Description
DELETE	/api/v1/invitations/{invitationId}	Cancelar una invitación pendiente (solo quien invitó; UC-14).

Error handling

Uniform error envelope defined as a reusable Error schema: { code, message, traceId }. No stack traces, SQL, internal names or secrets are ever returned. 409 responses disambiguate cause via code (e.g. INVITATION_ALREADY_PENDING vs. REMINDER_VERSION_CONFLICT).

HTTP code	Meaning
400	Validación de entrada fallida.
401	No autenticado (token ausente/ inválido).
403	Sin permiso sobre el recurso.
404	Recurso inexistente o no accesible.
409	Conflicto (p. ej. invitación duplicada pendiente).
410	Invitación expirada o ya resuelta.
429	Rate limit (especialmente creación de invitaciones).
500	Error interno.
503	Dependencia externa no disponible.

Operational healthcheck

An unauthenticated operational healthcheck (e.g. Spring Boot Actuator /actuator/health) exists outside this versioned business contract for orchestration/monitoring (NFR-006); it is intentionally not part of openapi.yaml.

24. Security Model

Baseline references: OWASP ASVS, OWASP API Security Top 10, OWASP MASVS, OWASP Top 10, NIST SSDF, NIST CSF, ISO 27001/27002/27701 (as reference frameworks — no formal compliance or certification is claimed).

Controls (V1)

- HTTPS everywhere
- Mature identity provider (Keycloak)
- Least privilege; per-object authorization
- Server-side validation
- Rate limiting
- Secrets management
- Encryption at rest (managed)
- Backups
- Logs without secrets
- Audit of sensitive actions
- SAST / SCA / secret scanning
- Up-to-date dependencies

Named security requirements

- SEC-001 — No user enumeration via invitations; uniform responses; rate limiting on invitation creation.
- SEC-002 — Invitation expiration, cancellation and revocation: CANCELLED is an INVITATION state (owner action, pre-acceptance); revocation is a REMINDER_SHARE state (owner action, post-acceptance), effective immediately.
- SEC-003 — Retention: 30-day soft-delete grace period for accounts; short-retention purge of invited-but-unregistered emails.

25. Threat Model

Assets: identity, session, personal data, reminders, credentials, database.

Threat	Mitigation
Credential stuffing / account takeover	Delegado a Keycloak: MFA, passkeys/WebAuthn, protección de fuerza bruta.
BOLA / IDOR	Autorización por recurso verificada server-side en cada endpoint; roles OWNER/COLLABORATOR.
Enumeración de usuarios vía invitaciones	SEC-001: respuesta uniforme, sin revelar existencia de cuenta; rate limiting.
Escalación de privilegios sobre recurso compartido	Verificación de rol OWNER/COLLABORATOR en cada endpoint, no solo en la UI.
Abuso de invitaciones (spam)	Rate limiting por usuario/IP sobre creación de invitaciones.
Acceso residual tras revocación	Validación de REMINDER_SHARE.status = ACTIVE en cada request, sin caché de autorización.
Abuso del canal de notificación push	Validar origen/adapter; no confiar en el payload para autorización.
Robo de token OIDC en el cliente Web (SPA)	Almacenamiento en memoria (no localStorage), CSP estricta, renovación silenciosa de tokens de vida corta.
Retención excesiva de PII de terceros	Purga de emails de invitados sin cuenta tras expiración/rechazo/cancelación (SEC-003, DEC-015).
Secretos expuestos / supply-chain	Secret scanning, SCA, SAST en CI; sin secretos en repositorio.
Condición de carrera al resolver una invitación	Transición PENDING → ACCEPTED/REJECTED/CANCELLED como actualización atómica condicional; solo una solicitud concurrente tiene éxito.
Actualizaciones perdidas sobre un recordatorio	Bloqueo optimista (REMINDER.version) en PATCH y complete; 409 ante conflicto.

Severity classification

- CRITICAL — account/data compromise or authorization bypass.
- HIGH — exploitation with meaningful impact.
- MEDIUM — requires additional conditions.
- LOW — limited impact.

26. Data Retention

Decision (DEC-015 / ADR-012): account deletion is a soft delete with a 30-day grace period. Requesting deletion moves `USER.deletion_status` to `PENDING_DELETION` and sets `purge_at` to +30 days; a periodic job purges personal data once that deadline passes. Whether the user can cancel a pending deletion request remains an open, non-blocking question.

Invitations left in `REJECTED`, `EXPIRED` or `CANCELLED` with no associated account (`invited_user_id` is null) purge the stored email after a short retention window (ASSUMPTION: 90 days) — a direct application of data minimization (NFR-002) to a third party who never used the service.

Push device tokens are removed on logout or when the owning account is purged.

27. CI/CD and Environments

Environments

Local development requirements: JDK 21, Android Studio, Android SDK, Git, Docker, PostgreSQL via Docker.

Local services for V1: PostgreSQL, backend, Android emulator/device. Redis, Kafka and Kubernetes are explicitly not added to V1 without a demonstrated need.

Pipeline (Pull Request)

- 1. Checkout
- 2. Dependency restore
- 3. Compile
- 4. Unit tests
- 5. Integration tests
- 6. Static analysis
- 7. Dependency / security scan
- 8. Secret scan
- 9. Build artifact

Pipeline (main branch)

All of the above, plus a reproducible build and a versioned artifact. Deployment to staging: TBD. Production requires approval and additional controls: TBD.

Security gates (V1)

- Secret scanning
- Dependency vulnerability scanning
- Automated tests
- Basic SAST
- Branch protection

Cloud target: AWS (DEC-008/ADR-009), enabling managed RDS (PostgreSQL) and, in the future, S3-compatible object storage.

28. Traceability Matrix

This table is a condensed view (Requirement/Use Case/API/Version) for readability. The full chain — Requirement → Use Case → Acceptance Criteria → API → Data Model → Architecture module → Backlog story → Test — is maintained in 12-traceability.md, rebuilt in this audit cycle to close every column for every requirement, including the previously untraced UC-14/AC-017 (cancel a pending invitation).

Requirement	Use case	API / UI	Version
FR-001	UC-01	Auth (Keycloak)	V1
FR-002	UC-02 / UC-06	Auth (Keycloak)	V1
FR-003	UC-03 / UC-04	Home	V1
FR-004	UC-03 / UC-04 / UC-05	Reminders API	V1
FR-005	UC-03 / UC-11	Notification (local)	V1
FR-006	UC-06	Settings	V1
FR-007	UC-07	Reminders Shares API	V1
FR-008	UC-08	Invitations API	V1
FR-009	UC-07 / UC-08	Reminders API (authorization)	V1
FR-010	UC-09 / UC-10	Invitations / Shares API	V1
FR-011	UC-11	Notification (push, FCM)	V1
FR-012	UC-12	Devices API	V1
FR-013	UC-13	Account API	V1
NFR-010	UC-13	Account / Invitations (retention)	V1

Rule: no approved requirement enters development without a stable identifier, a use case, an acceptance criterion, and a mapping to API/data model/architecture/backlog. The Test column in 12-traceability.md reads "Pending (pre-code)" for every row — an honest, explained status for a documentation-only phase, not a hidden gap.

29. Acceptance Criteria

ID	Title	Summary
AC-001	Registro	Cuenta creada solo con datos válidos; no se revela información que permita enumerar cuentas.
AC-002	Login	Credenciales válidas permiten acceso; sesión válida permite consumir recursos autorizados.
AC-003	Crear recordatorio	Título obligatorio y longitud máxima respetada; el recurso pertenece al usuario autenticado; 201 con identificador.
AC-004	Acceso a recordatorio	El propietario consulta; otro usuario recibe 404 o 403 según política definida, sin revelar existencia.
AC-005	Completar	Estado único global (DEC-001); operación idempotente; cualquier usuario con acceso puede alternarlo; version opcional valida bloqueo optimista (409 si no coincide).
AC-006	Error	Sin stack traces; toda respuesta de error incluye traceld.
AC-007	Compartir recordatorio	Solo el propietario invita; invitación PENDING con expiración a 7 días; 409 ante invitación duplicada pendiente.
AC-008	Aceptar invitación	Solo el destinatario acepta; invitación expirada/resuelta responde 410; se crea REMINDER_SHARE ACTIVE.
AC-009	Rechazar invitación	Solo el destinatario rechaza; no otorga acceso; notifica al propietario.
AC-010	Revocar acceso	Solo el propietario revoca; efecto inmediato.
AC-011	Permisos de colaborador	Ver y completar/deshacer; 403 al intentar editar, eliminar o re-compartir.
AC-012	Notificación push	Eventos de invitación/revocación/eliminación/cambios generan push vía FCM; fallo de push no rompe la operación principal.
AC-013	Eliminar recordatorio compartido	Solo el propietario elimina; colaboradores activos son notificados; cascada de INVITATION/REMINDER_SHARE.
AC-014	Registro de dispositivo push	Un usuario puede registrar múltiples dispositivos; solo puede eliminar sus propios registros.
AC-015	Eliminar cuenta	DELETE /me responde 202; cuenta pasa a PENDING_DELETION; purga definitiva a los 30 días.
AC-016	Purga de invitaciones sin cuenta	Invitaciones REJECTED/EXPIRED/CANCELLED sin cuenta asociada purgan el email tras un plazo corto de retención.
AC-017	Cancelar invitación pendiente	Solo el inviter cancela una invitación PENDING (→ CANCELLED, nunca REVOKED); si ya está resuelta, responde 410.

30. Decision Log

Architecture Decision Records

ADR	Title	Status	Summary
ADR-001	Monolito modular	Accepted	Monolito modular con límites de dominio; no microservicios en V1.
ADR-002	Android nativo	Accepted	Kotlin + Jetpack Compose.
ADR-003	IA fuera de V1-V4	Accepted	Reduce superficie de datos, coste y complejidad.
ADR-004	Finanzas fuera de V1-V4	Accepted	Reduce riesgo de seguridad, privacidad y confianza.
ADR-005	Plataformas V1	Accepted	Android + iOS + Web desde el inicio, mismo backend/API/modelo de datos.
ADR-006	Modelo de compartir	Accepted	Owner + colaboradores 1:N vía invitación; refinado con DEC-001/002/003.
ADR-007	Notificaciones push	Accepted	Interfaz propia PushNotificationSender; proveedor FCM unificado (DEC-010); DEVICE_PUSH_TOKEN (DEC-005).
ADR-008	Proveedor OIDC	Accepted	Keycloak (DEC-004); verificación de email delegada (DEC-014); sin login propio.
ADR-009	Cloud provider	Accepted	AWS (DEC-008).
ADR-010	Stack iOS	Accepted	Swift + SwiftUI nativo (DEC-006).
ADR-011	Stack Web	Accepted	React + TypeScript, SPA (DEC-007).
ADR-012	Retención y eliminación de cuenta	Accepted	Soft delete 30 días + purga de invitaciones sin cuenta (DEC-015).

V1 Decision Pack (approved 2026-08-09)

ID	Topic	Approved value
DEC-001	Estado de completado	A — Estado único global por recordatorio.
DEC-002	Eliminación con colaboradores	C — Eliminar y notificar a los colaboradores activos.
DEC-003	Lifecycle de INVITATION	A — PENDING/ACCEPTED/REJECTED/EXPIRED/CANCELLED; revocación solo en REMINDER_SHARE.
DEC-004	Proveedor OIDC	A — Keycloak.
DEC-005	Almacenamiento de push tokens	A — Tabla DEVICE_PUSH_TOKEN, multi-dispositivo.
DEC-006	Stack iOS	A — Swift + SwiftUI.
DEC-007	Stack Web	A — React + TypeScript, SPA.
DEC-008	Cloud provider	A — AWS.

ID	Topic	Approved value
DEC-009	Proveedor de correo	A — Amazon SES.
DEC-010	Proveedor de push	A — Firebase Cloud Messaging unificado.
DEC-011	Android mínimo	B — API 30 (Android 11).
DEC-012	iOS mínimo	A — iOS 17.
DEC-013	Navegadores soportados	A — Últimas 2 versiones mayores evergreen + variantes móviles.
DEC-014	Verificación de email	C — Delegada a Keycloak; sin sistema propio.
DEC-015	Retención/eliminación de cuenta	B + A' — Soft delete 30 días + purga de invitaciones sin cuenta.

31. Open Questions

None of the following block the start of V1 core development (29-v1-final-readiness.md). They remain explicitly TBD — no value has been assumed on the Product Owner's behalf.

Category	Open question
Producto	¿Nombre definitivo del producto?
Producto	¿Mercado/país inicial?
Producto	¿Primer grupo de usuarios de validación?
Producto	¿Licencia y organización del repositorio?
Producto	¿Cuenta real requerida o modo local/offline previo?
Producto	¿Se requiere modo offline en V1?
Producto	¿Límite máximo de colaboradores por recordatorio?
Producto	Formato/reglas exactas del username.
Producto	¿Notificar al colaborador si el propietario edita el recordatorio?
Producto	¿Auto-vincular invitación pendiente si el invitado se registra después?
Producto	¿Se puede revertir una solicitud de eliminación de cuenta (PENDING_DELETION)?
Técnico	¿Despliegue en AWS desde el inicio o entorno local/staging primero?
Técnico	Dispositivos soportados más allá de la versión mínima de SO.
Técnico	Patrón final de manejo de tokens OIDC en el cliente Web SPA.

32. V1 Readiness

V1_READINESS_STATUS: READY for core V1 development (29-v1-final-readiness.md).

All five blockers identified in the initial readiness review (27-v1-readiness-review.md) were resolved by the approved decision pack: shared-reminder completion semantics, deletion behaviour for shared reminders, the INVITATION lifecycle, the OIDC provider, and the push-token storage model.

Corrected documentation conflicts

- POST /auth/login — removed from the intended design; the application never implements its own login endpoint (resolved by ADR-008 / Keycloak).
- INVITATION lifecycle — corrected to include CANCELLED and exclude REVOKED (DEC-003).
- Shared-reminder completion ambiguity — resolved to a single global state (DEC-001).
- Undefined deletion behaviour for shared reminders — resolved to cascade + notify (DEC-002).
- Missing push-token storage — resolved with DEVICE_PUSH_TOKEN (DEC-005).

Minor drift found in the pre-generation consistency review (30-documentation-consistency-review.md)

No blockers. A short list of stale wording and coverage gaps (e.g. a leftover "TBD by platform" note in a flow diagram, one use case not yet updated with the Keycloak wording used elsewhere, the "cancel invitation" action lacking its own use case and acceptance criterion) was identified and reported, without being silently corrected in the source Markdown.

V1 development gate audit (32-v1-development-gate-audit.md)

A subsequent, independent audit ("V1 development gate") validated an external (Gemini) findings report against the ADR/decision log, and corrected every real finding directly in the source documentation: the stale REVOKED reference in 07-backend-architecture.md, the stale FCM/APNs "TBD by platform" wording and missing events in 05-user-flows.md, the historical-but-unmarked paragraph in ADR-007, UC-02's "backend creates a session" wording, the phantom POST /auth/logout endpoint in 10-api-openapi.md (removed — logout is client-side plus DELETE /me/devices/{deviceId}), and a self-contradiction in 01-scope.md about the iOS/Web stack. It also closed real technical gaps in openapi.yaml (OAuth2/OIDC securityScheme, reusable Error schema, pagination, request bodies for POST/PATCH /reminders, optimistic-locking version field, \$ref usage in responses) and in the data model (REMINDER.version, DEVICE_PUSH_TOKEN.token uniqueness, atomic invitation-state transitions), added the missing UC-14/AC-017 for cancelling a pending invitation, and rebuilt 12-traceability.md to close the full Requirement → Use Case → Acceptance Criteria → API → Data Model → Architecture → Backlog → Test chain. See 32-v1-development-gate-audit.md for the full classification of every reviewed finding.

Remaining TBDs (non-blocking)

See Section 31. All are product-level naming/market/UX-edge-case questions or implementation-level technical details that can be resolved in parallel with development without reworking anything already decided.